保护自己免遭反病毒的危害

传统反病毒 (AV) 技术并非防御端点安全漏洞的解决方案，而是问题所在。反病毒技术在阻止当今的网络威胁方面已不再有效。虽然反病毒技术满足了许多法规、监管和合规性方面的要求，但是它也增加了组织的隐性成本，同时它所提供的实际安全价值聊胜于无。尽管传统反病毒解决方案几乎“保护”着全世界所有的端点和服务器，但安全漏洞仍在不断增加，这就是一个很好的例证。选择用更先进的技术替换其传统反病毒技术的组织应选择一款可以提供出色安全价值的产品，这一点不仅指金钱成本，还要考虑产品的安全效力。

本文档概述了传统反病毒技术无法再为组织提供任何有意义的安全价值的三个核心原因。本文档将目光放到了有形的人员配置、运营及许可和支持成本之外，重点强调了与操作反病毒系统相关的一些隐性成本，这种成本可能是无形的、难以量化的或因优先级的问题而未引起重视。

文档中还介绍了任何反病毒替代技术或产品要防御端点安全漏洞所必须满足的五个安全要求。本文档最后还讨论了 Palo Alto Networks® Traps 的高级端点防护如何能够让组织将其传统反病毒技术替换成最有效、专用的恶意软件和漏洞预防方法，从而保护其端点免遭已知和未知威胁的侵害。

目录

执行摘要	**1**
反病毒技术无法再提供有意义的安全价值	**3**
反病毒技术的隐性成本	**4**
反病毒替代技术的 5 个安全要求	**5**
以 Traps 替代反病毒	**6**
结语	**8**

反病毒技术无法再提供有意义的安全价值

根据大多数报道，传统反病毒技术自 1987 年就已存在。[1] 自此，基于签名的文件扫描成为了反病毒技术检测恶意内容功能的基石。但随着操作系统、网络和应用程序日趋高级和复杂，此技术的效力也在日渐削弱。如今，传统反病毒技术已无法再为仍部署该技术的组织提供有意义的安全价值。事实上，安全从业者现在所可以使用的出色的技术与产品不仅能够消除对传统反病毒技术的需求，而且在实际安全价值方面也远远超越了后者。

效力是确定技术或产品安全价值的最关键因素。而安全效力至少要通过技术提供以下三种核心功能的能力来衡量：

1. **预期功能的性能：**技术是否能实现其预计执行的安全功能？
2. **内在持久性：**技术是否可以防止攻击者和用户绕过其安全功能？
3. **灵活性：**技术是否会不断进化，以适应并保护新的应用程序、系统和平台？

强加密便是一种可以持续提供有意义的安全价值的安全技术，因为它依旧是实现安全的有效手段。加密旨在通过“以只有授权方可以读取的方式对消息和信息进行编码”来防止信息失去保密性。[2] 通过加密仍可成功执行这一功能。由于强加密本身的特性，它还可以实现内在持久性：它可以防止攻击者轻而易举地绕过安全功能。最后，强加密仍具有灵活性：它一直在不断的进化，通过采用新的算法、不断增强计算能力以及采用基于硬件的实施来适应新的应用程序。

另一方面，反病毒技术则是一种无法再提供有意义的安全价值的安全技术，因为它不再是实现安全的有效手段。

预期功能的性能

从广义上讲，传统反病毒技术的主要预期功能是防止攻击者侵害端点和服务器。在 1980 年代后期及整个 1990 年代，考虑到那一时期的攻击的特性、复杂程度和频率，基于签名的反病毒技术足以执行此功能。但是，在当今的计算环境下，反病毒技术已无法再成功地执行此功能，反病毒供应商也已坦率地承认了这一事实。[3]

攻击者主要依赖两种攻击途径来侵害端点：恶意可执行文件（恶意软件）和漏洞利用。这些攻击途径可以单独使用，也可以通过不同的组合形式出现，但其性质存在本质区别：

- **恶意软件**大多是独立的恶意可执行文件，主要针对系统执行违法活动。
- **漏洞利用**是恶意的数据文件或内容，旨在利用合法应用程序中的软件缺陷或漏洞为攻击者提供远程代码执行功能。通过成功的漏洞利用，攻击者可以在目标端点上远程执行恶意软件。

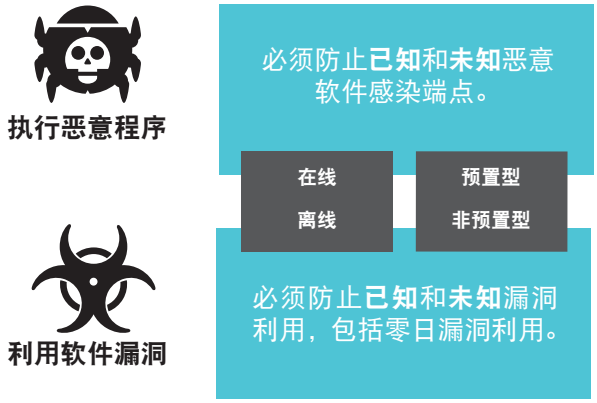

图 1：有效的端点安全必须能够防止恶意软件和漏洞利用

若要防止攻击者侵害端点和服务器，安全技术或产品必须能够预防恶意软件和漏洞利用（图 1）。此外，它还必须能够预防每个恶意软件和漏洞利用的已知与未知变种。不幸的是基于签名的扫描和传统反病毒技术已无法检测漏洞攻击，并且也无法扫描或预防不具有签名的恶意软件或漏洞利用。

内在持久性

传统反病毒技术自出现以来就深陷缺乏内在持久性的困境之中。用户一直担心因反病毒系统扫描造成的干扰和系统迟缓。认识到这些中断对用户和业务流程的影响之后，反病毒供应商为用户提供了一个选项，使用户可以在完成业务优先级受到干扰时跳过病毒扫描。因此，如果可能，用户会习惯性地绕过计划扫描或停用反病毒组件。

最近，攻击者已可以使用基于云的编码和多重扫描工具，自动绕过市场上的大多数传统反病毒产品。许多这类工具都提供了与各种漏洞利用工具包的集成，可以自动确定在什么时候特定攻击无法再绕过传统反病毒技术，并自主选择可以绕过反病毒的其他攻击。

灵活性

基于签名的反病毒技术一直在努力适应新的应用程序、系统和平台，它们无法适应或并不适合部署签名数据库和基于签名的扫描。在虚拟桌面基础设施 (VDI) 中部署的桌面和服务器系统就是这种环境的完美示例。虚拟系统实例化之后，必须先下载最新的反病毒签名，然后其反病毒技术才可以执行预期的安全功能，在此期间，系统将会暴露在攻击之下。

实际上，这种缺乏灵活性的问题多年来一直损害着传统反病毒技术的效力。然而传统反病毒技术的初衷只是为了防止计算机病毒感染系统，其缺乏灵活性且无法适应日益变化的威胁环境的特点，几乎已将基于签名的反病毒技术降级成一种过时的被动安全工具。

反病毒技术不仅无法再提供有意义的安全价值，而且还令组织负担了难以察觉的隐性成本。

反病毒技术的隐性成本

安全技术和产品并非存在于真空中。它们是工具生态系统的一部分，必须为组织的目的和目标提供支持。将更严格的安全需求与增强用户开展业务能力的需求相平衡一直是争论不断的话题。同样，安全技术也必须将其为组织提供的效益与和运营相关的成本相平衡。与运营反病毒系统相关的成本已扩展到了有形的人员配置、运营及许可和支持成本之外，而可能是无形的、难以量化的或因优先级的问题而未引起重视的成本。

操作灵活性

如前所述，传统反病毒技术非常依赖老旧的基于签名的扫描技术，在支持新应用程序、系统和平台方面不是特别灵活。因此，仍然依赖反病毒技术的组织在部署和保护可以提供显著业务优势的新技术（例如，VDI）时难免会遇到阻碍。

机会成本

支持、运营和维护反病毒系统需要组织分配人员、时间和资源，而他们也可用于支持其他更具投资回报的项目。通常，安全员工不仅需要支持老化的反病毒系统，还需要从多个可能需要更长时间整合且安全效力更低的解决方案中拼凑出一项安全功能。

虽然合规但未缓解风险

大多数安全专家都会同意这样的说法，即遵从法规并不等于安全。尽管许多遵从性和法规框架（如支付卡行业数据安全标准 (PCI-DSS) 与健康保险携带和责任法案 (HIPAA)）都要求组织使用传统反病毒技术的各种功能，但遵守这些要求并不能保证可以充分减轻安全风险。如前所述，传统反病毒技术无法在当今的计算环境下提供有意义的安全价值，迫使安全专家不得不部署其他技术和产品来减轻反病毒技术无法解决的安全风险，这种情况反过来又会为组织增加额外的有形和无形成本。

错误的安全感

从最终用户的角度来看，组织的各种 IT 和安全功能应负责保证其网络、系统和计算环境的安全。尽管如此，组织的安全意识培训计划仍将安全描述为“每一个人的责任”。用户通常都认定负责这些功能的专家可以确定用户的系统上必须部署哪种工具和技术，从而让用户能够安全地开展每日业务活动。当组织选择部署传统反病毒

技术，也就是上文所述的无法再提供有意义的安全价值的安全技术时，用户可能会错误地认为他们的系统已受到保护，可以免遭攻击。产生错误的安全感反过来会导致用户放松警惕，并且在避免潜在网络威胁时不再如之前一般谨慎小心。

组织可以通过将这种老旧的技术替换为不仅可以消除对传统反病毒技术的需求，而且在实际安全价值方面也远远超越后者的产品，避免支出无形的、难以量化的或未引起重视的反病毒成本。

反病毒替代技术的 5 个安全要求

如前所述，选择用更先进的技术替换其传统反病毒技术的组织应选择一款可以提供出色安全价值的产品，这一点不仅指金钱成本，还要考虑产品的安全效力。具体而言，高级端点防护产品应提供如下五项功能。

1. **以预防为首任**

   随着网络漏洞的频率、种类的不断增加和复杂程度的日益上升，整个安全行业一直在努力防止成功入侵，但时常会以失败告终。该行业对改进检测和响应时间的过多关注是导致此失败的一项重要原因。更好的检测只能缩小检测到攻击的空窗期，但对于在侵害发生之前保护宝贵信息的需求却无能为力。勒索软件成功攻击在最近的上升态势令这一缺点变得愈发明显。

   漏洞检测和事故响应确实可以提供安全价值，但与预防相比都是次要的。预防为主对于降低网络攻击频率和影响是唯一有效、可扩展且可持续的途径。

2. **预防已知和未知恶意软件**

   防御端点安全漏洞的完整解决方案还必须能够预防已知和未知恶意软件的成功执行。为了避免出现与基于签名的反病毒技术相关的弊端，理想产品的恶意软件防护功能不应涉及签名，也不应要求事先具备关于恶意软件实例的知识以防止其执行。此外，若要有效预防常见和高级的恶意软件 4，就必须部署多种可通过调优来发挥最大效力的分析和预防方法。

3. **预防已知和零日漏洞利用**

   寻求以最有效的方式绕开现有端点安全措施的威胁执行方依赖的是漏洞利用，特别是那些利用未知软件弱点的漏洞利用（通常称为“零日漏洞利用”）。零日漏洞利用嵌入到 Adobe® PDF 和 Microsoft® Word 文档等专门制造的数据文件和内容中，通过破坏合法应用程序来执行违法活动。其对于传统反病毒解决方案的规避能力以及供应商安全补丁的缺乏，常常使得组织无法采取针对零日漏洞利用的预防措施，这也通常构成了针对性攻击的最初阶段。因此，防御端点安全漏洞的完整解决方案必须能够防止已知和未知漏洞利用破坏合法应用程序。

4. **自动集成威胁情报**

   随着免费和低成本工具的日益泛滥，威胁执行方可以快速生成独一无二的新攻击以规避基于签名的传统反病毒技术的检测。根据 Verizon 2016 年数据泄露调查报告显示，81.9% 的网络攻击可以在几分钟内成功侵害其目标。组织必须使用在别处遇到独特的新攻击时获取的威胁情报来预防自身环境中的安全漏洞，这一点至关重要。反病毒技术的替代产品必须原生集成并利用来自全球资源的威胁情报来自动检测已知恶意软件，同时快速识别未知恶意软件，从而阻止二者感染组织系统。

5. **全面防护**

   组织的工作者的移动性正在不断提高。他们会通过全球各地的位于组织网络边界之外的位置连接到内部资源。他们会使用基于云的软件即服务 (SaaS) 和存储解决方案来处理和共享数据，甚至当他们从组织网络断开连接时也是如此。这些服务和解决方案可以在组织的全体员工之间同步并分发文件，包括恶意软件和漏洞利用。因此，防御端点安全漏洞的完整解决方案必须能够防止恶意软件和漏洞利用侵害系统，无论系统处于在线还是离线状态、是否连接到组织网络或物理位置位于何处（内部或外部）。

其他考量因素

产品的安全功能常常是组织寻求替换传统反病毒技术时的首要考量因素。但是，也有其他的非安全考量因素，可能会对产品是否满足组织反病毒技术替换要求具有重要影响。

运行效率

如上文所述，反病毒文件扫描的侵入性以及所造成的用户系统迟缓，已成为引起用户和 IT 管理员不满的主要原因。因此，最佳的反病毒技术替代产品必须将侵入性将至最低（最理想的是对用户透明），同时降低对内存、带宽和 CPU 资源的要求。

支持无法打补丁的系统

并非每个组织都可以（或都愿意）升级现有的生产系统。组织可能会选择不应用可用的系统更新和安全补丁，因为这样做会干扰、削弱或阻止关键的运营功能。或者，他们也可能无法应用这样的更新，因为系统或软件已达到终止支持状态并且相应的供应商不再提供系统和安全更新。因此，完整的反病毒替代产品必须支持并保护这些本质上已“无法打补丁”的系统和软件应用程序。

满足业务需求的可定制性

组织对反病毒替代产品的业务需求可能会各不相同。这种情况下，一种方法不能满足所有要求。只有灵活的、混合式的多重方法防御手段才能适应组织中以及组织内用户组中的各种不同的业务要求。理想的反病毒替代产品必须提供足够的灵活性，使得可以通过对安全进行调优来满足组织的业务要求。

以 Traps 替代反病毒

尽管传统反病毒解决方案几乎“保护”着全世界所有的端点和服务器，但安全漏洞仍在不断增加。要防御端点安全漏洞，组织必须保护自己免遭侵害，不仅需要对抗已知和未知的网络威胁，还要预防在环境中部署的无效反病毒解决方案。

Palo Alto Networks Traps 的高级端点防护将传统反病毒技术替换成了多重方法防护产品，该产品将最有效的专用恶意软件和漏洞利用预防方法进行独特的组合部署，可以在已知和未知威胁侵害端点之前对其进行预防。

多重方法恶意软件防护

Traps 利用可最大范围地抵御恶意软件的独特方法防止恶意可执行文件，同时减少攻击面，提高检测恶意软件的准确度。此方法结合了多层防护措施，它们能够即时阻止已知和未知恶意软件感染系统（图 2）：

1. **通过机器学习进行静态分析：**此方法可以在允许运行任何未知可执行文件之前对其进行即时判定。通过在极短的时间内检查数百个文件的特征，可以确定文件可能是恶意还是良性，无需依赖签名、扫描或行为分析。
2. **WildFire 检测和分析：**本方法利用 Palo Alto Networks WildFire 基于云的恶意软件分析环境的强大功能，对未知恶意软件进行快速检测，并自动对 Traps 进行重新编程以预防已知恶意软件。WildFire 可以在约 300 秒内将未知威胁转换成已知威胁，从而消除未知威胁。

图 2：Traps 的多重方法恶意软件防护

3. **受信任发布者执行限制：**此方法允许组织识别“未知但良好”的可执行文件，因为对其进行发布和数字签名的受信任发布者、实体已由 Palo Alto Networks 识别为信誉良好的软件发布者。

4. **基于策略的执行限制：**组织可以轻松地定义策略来限制特定的执行场景，从而减少所有环境的攻击面。例如，Traps 可以阻止从 Outlook“temp”目录中执行文件或直接从 USB 驱动中执行特定文件。

5. **管理员替代策略：**此方法允许组织根据可执行文件的哈希定义策略，从而控制在所有环境中允许运行和不允许运行的文件。这种细粒度的白名单（或黑名单）功能可以根据用户定义的条件控制所有文件的执行。

除了上述恶意软件预防方法，Traps 还会隔离恶意可执行文件以防止将感染文件传播给其他用户。虽然此功能在大多数环境中必不可少，但它对预防恶意软件在组织中的意外传播尤为有用，这些组织中的基于网络或基于云的数据存储应用程序会自动在多个用户和系统间同步文件。

将上述方法和功能结合在一起不但能使 Traps 防止已知和未知恶意软件侵害系统，还可以使组织能够全面定制防御方法来满足其不断变化的业务需求。

多重方法漏洞利用防护

许多目标性攻击首先采用的都是以数据文件形式通过网站、电子邮件或网络转播的漏洞利用。当用户打开该文件时，其中嵌入的恶意代码就会利用用于查看该文件的应用程序中的漏洞来破坏应用程序并执行攻击者的指令。由于很难将这种攻击类型与正常的应用程序行为区分开来，因此它将会绕过传统的反病毒技术和大多数端点安全解决方案。此外，如果被利用的应用程序经过了 IT 安全策略的允许，则该攻击也将会绕过所有的白名单控制。

Traps 使用全新的独特方法来预防漏洞利用。Traps 并不关注数百万的单个攻击或其底层软件漏洞，而是将重心放在了所有基于漏洞利用的攻击都使用的核心漏洞利用技术。尽管漏洞利用有成千上万种，但其所依赖的只是一小部分鲜有变化的核心技术。此外，每个漏洞利用都必须使用一系列这种漏洞利用技术才能成功破坏应用程序。Traps 通过在其尝试攻击的时刻识别并预先拦截这些技术，使其无法发挥效力。使用 Traps 的组织可以运行任何应用程序，包括内部开发的应用程序和无法再接收安全支持的应用程序，而不会对其环境产生迫切的威胁。

Traps 实施多重方法途径来预防漏洞利用，同时结合多层防护来阻止漏洞利用技术（图 3）：

1. **内存损坏 / 操纵预防：**内存损坏是一类漏洞利用技术，其中的漏洞利用可操纵操作系统中用于应用程序的正常内存管理机制，来打开包含该漏洞利用的恶意数据文件。内存损坏预防方法可以在这类漏洞利用技术成功破坏应用程序之前将其识别并进行阻止。

2. **逻辑缺陷预防：**逻辑缺陷也是一类漏洞利用技术，漏洞利用可以通过它操纵操作系统中用于支持和执行目标应用程序的正常流程，来打开恶意数据文件。例如，该漏洞利用可以将动态链接库 (DLL) 加载的位置更改成应用程序的执行环境，从而使漏洞利用的恶意 DLL 可以替换合法的 DLL。逻辑缺陷预防方法可以在这些漏洞利用技术成功执行之前将其识别并进行阻止。

3. **恶意代码执行预防：**大多数情况下，漏洞利用的最终目标是执行一些任意代码，也就是嵌入到漏洞利用数据文件中的攻击者命令。恶意代码执行预防方法可以在允许执行攻击者的恶意代码的漏洞利用技术成功之前将其识别并进行阻止。

图 3：Traps 的多重方法漏洞利用防护

利用上述方法，Traps 可以持续有效且透明地防止已知和零日漏洞利用侵害系统。这种预防方法可以保护应用程序和系统，无论其是否接收安全补丁，也不管其网络连接或物理位置如何。

新一代安全平台

Traps 是唯一一款可以将从拥有超过 10,000 位 WildFire 订阅者的全球社区以及多个威胁情报源中获取的威胁情报自动转换为恶意软件防护的端点防御产品。当 WildFire 将可执行文件识别为恶意文件时，无论该威胁情报是从何处获取的，Traps 都会自动重新编程以便从那一刻开始阻止该文件的执行。进行自动重新编程并将威胁情报转换成预防几乎可以消除攻击者利用未知和高级恶意软件感染系统的机会。无论在世界的任何地方，一个恶意软件攻击者最多只能使用一次，并且在 WildFire 致使其完全无效之前，它只有几秒钟的时间可以执行攻击。

通过将 Traps 与 Palo Alto Networks 新一代安全平台进行集成，组织能够将从成千上万个企业客户的网络和端点中获取的越来越多的威胁情报持续应用到其自身环境中。

结语

传统反病毒技术无法再提供有意义的安全价值，因为它不再是防御安全漏洞的有效手段。现在，组织所可以使用的出色的技术不仅能够消除对传统反病毒技术的需求，而且在实际安全价值方面也远远超越了后者，同时组织还可以避免支出无形的、难以量化的或未引起重视的反病毒技术成本。Palo Alto Networks Traps 的高级端点防护将传统反病毒技术替换成了多重方法防护产品，该产品将最有效的专用恶意软件和漏洞利用预防方法进行独特的组合部署，可以在已知和未知威胁侵害端点之前对其进行预防。

欲了解 Traps 的更多信息，请下载 **Traps 产品说明书**或 **Traps 技术概览**。或者，通过参加**终极产品体验**活动亲自体验 Traps，或联系销售代表为您的组织安排一次内部评估。

[1] https://en.wikipedia.org/wiki/Antivirus_software
[2] https://en.wikipedia.org/wiki/Encryption
[3] http://www.wsj.com/articles/SB10001424052702303417104579542140235850578
[4] 高级恶意软件包括那些部署目标性或多重感染机制、触发器和负载，并利用自加密和多态性等隐秘策略的恶意软件。

4401 Great America Parkway
Santa Clara, CA 95054
总机： +1.408.753.4000
销售： +1.866.320.4788
支持： +1.866.898.9087
www.paloaltonetworks.com

© 2016 Palo Alto Networks, Inc. Palo Alto Networks 是 Palo Alto Networks 的注册商标。有关本公司的商标列表，请访问: http://www.paloaltonetworks.com/company/trademarks.html。此文档中提及的所有其他商标可能是各相应公司的商标。antivirus-protect-yourself-wp-072716